

Національний технічний університет України
«Київський політехнічний інститут імені Ігоря Сікорського»
Науково-навчальний інститут фізико-технічний інститут
Кафедра інформаційної безпеки

Лабораторна робота №3

з дисципліни: «Блокчейн та децентралізовані системи»
Тема: «Дослідження безпечної реалізації та експлуатації
децентралізованих додатків.»

Виконав студент групи ФБ-52мп: Марченко Дмитрій

Перевірила: Селюх П.В.

Київ 2026 рік

ЗМІСТ

Вступ	3
1 Аналіз вимог OWASP Top 10:2021	4
1.1 A01:2021 - Broken Access Control	4
1.2 A02:2021 - Cryptographic Failures	5
1.3 A03:2021 - Injection	5
1.4 A04:2021 - Insecure Design	5
1.5 A05:2021 - Security Misconfiguration	5
1.6 A06:2021 - Vulnerable and Outdated Components	6
1.7 A07:2021 - Identification and Authentication Failures	6
1.8 A08:2021 - Software and Data Integrity Failures	6
1.9 A09:2021 - Security Logging and Monitoring Failures	6
1.10 A10:2021 - Server-Side Request Forgery (SSRF)	7
2 Архітектура протоколу Aave v3	7
3 OWASP Smart Contract Top 10 (2025)	9
4 Зіставлення OWASP з безпекою Aave v3	11
5 Перелік вимог безпеки для dApp Aave v3	13
6 Зведена таблиця відповідності вимог	17
Висновки	18
Список використаних джерел	19

Вступ

Децентралізовані фінансові протоколи (DeFi) на сьогодні є одним із найбільш динамічно розвинених секторів індустрії блокчейну. Серед усіх класів dApp особливе місце займають протоколи кредитування та запозичення, оскільки вони акумулюють значні обсяги ліквідності та оперують механізмами, що дозволяють користувачам отримувати позики під заставу цифрових активів. Станом на початок 2026 року сукупна заблокована вартість (TVL) у DeFi перевищила 200 мільярдів доларів США, причому лідери ринку - Aave, Compound і MakerDAO - утримують понад третину цього обсягу [1].

У цій лабораторній роботі я обрав протокол Aave v3 як об'єкт дослідження. Aave - це децентралізований нон-кастодіальний протокол ліквідності, який розгорнутий на Ethereum та понад десяти інших мережах (Polygon, Arbitrum, Optimism, Base, Avalanche тощо). Протокол дозволяє постачальникам ліквідності отримувати відсотки за депозити, а позичальникам - брати кошти під надмірне або, за певних умов, ненадмірне забезпечення (uncollateralized flash loans). Aave v3 впровадив архітектурні нововведення, що суттєво відрізняють його від попередніх версій: механізм eMode (efficiency mode), порталний міст між мережами, покращену систему ризик-параметрів та вдосконалений модуль безпеки StakerAave (Safety Module) [2].

Вибір Aave v3 зумовлений рядом чинників. По-перше, протокол є унікальною системою, яка поєднує складну on-chain бізнес-логіку зі значними off-chain компонентами (governance, oracle, risk parameters). По-друге, Aave регулярно проходить аудити, публікує звіти та підтримує активну програму bug bounty, що дозволяє проводити ґрунтовний аналіз вимог безпеки. По-третє, саме в 2025–2026 роках декілька DeFi-кредитних протоколів зазнали атак, що актуалізує тематику лабораторної роботи [3].

Метою роботи є: дослідити вимоги OWASP Top 10:2021 у контексті безпеки web-додатків; зіставити ці вимоги з архітектурою Aave v3; скласти структурований перелік аналогічних вимог безпеки, адаптованих до специфіки децентралізованого протоколу кредитування.

1 Аналіз вимог OWASP Top 10:2021

OWASP Top 10 - це документ щодо найкритичніших ризиків безпеки веб-застосунків. Чинна редакція 2021 року є результатом аналізу понад 500 000 реальних додатків і включає низку нових категорій порівняно з версією 2017 року [4]. Нижче стисло охарактеризовано кожен категорію з акцентом на те, що змінилося у розумінні ризику, і яке значення це має для децентралізованих додатків.

1.1 A01:2021 - Broken Access Control

Контроль доступу піднявся з 5-ї позиції у 2017 до першого місця у 2021 році. Категорія охоплює порушення принципу мінімальних привілеїв, обхід перевірок авторизації через маніпуляцію URL або станом додатка, незахищені прямі посилання на об'єкти (IDOR), а також надання непотрібних дозволів неавторизованим користувачам [4]. У класичних web-системах контроль доступу забезпечується серверним middleware і RBAC-моделями. У dApps функцію авторизаційного «сервера» виконує сам смарт-контракт через модифікатори Solidity та зберігання ролей у змінних стану.

1.2 A02:2021 - Cryptographic Failures

Перейменована з «Витоку конфіденційних даних» (2017), ця категорія тепер зосереджується на першопричинах: слабких або застарілих алгоритмах шифрування, неправильному управлінні ключами, передачі даних у відкритому вигляді, використанні слабких PRNG. OWASP рекомендує AES-256 для симетричного шифрування, RSA-2048+ або Curve25519 для асиметричного, SHA-256/SHA-512 для хешування [4]. Для Ethereum усі підписи транзакцій покладаються на secp256k1 ECDSA, що є криптографічно міцним, однак помилки на рівні управління ключами (зберігання seed-фраз, підпис фішингових запитів) залишаються актуальними.

1.3 A03:2021 - Injection

Класичні ін'єкційні атаки (SQL, OS command, XSS) відбуваються, коли шкідливі дані передаються до інтерпретатора як частина команди. Для веб-компонентів dApp - React/Next.js фронтенд, API-шлюзи, backend-сервіси governance - ці вектори повністю актуальні. На рівні смарт-контрактів аналогом ін'єкції є зловмисно сконструйовані calldata, які експлуатують недоліки парсингу або callback-логіки.

1.4 A04:2021 - Insecure Design

Нова категорія 2021 року підкреслює перехід від «виправлення вразливостей» до «безпеки за дизайном». Вона стосується фундаментальних архітектурних недоліків, які неможливо усунути на рівні реалізації. Для незмінних смарт-контрактів це особливо критично: дефект дизайну, виявлений після деплою, потребує міграції з усіма пов'язаними ризиками та витратами.

1.5 A05:2021 - Security Misconfiguration

Категорія охоплює дефолтні облікові дані, зайві відкриті порти, відсутність заголовків безпеки, розкриття стекових трасувань, застарілі компоненти на рівні конфігурації. Для

фронтенду Aave - це відсутність строгої Content Security Policy, неправильна конфігурація CORS або DNSSEC. Для смарт-контрактів - помилкові параметри ініціалізації (наприклад, неправильна адреса Price Oracle при деплої).

1.6 A06:2021 - Vulnerable and Outdated Components

Більшість сучасних dApp залежать від сотень прм-пакетів і зовнішніх бібліотек смарт-контрактів. OWASP рекомендує ведення реєстру компонентів (SBOM), регулярну перевірку CVE/NVD та автоматичне сканування залежностей [4]. Для Aave це означає актуальність версій OpenZeppelin, ethers.js, wagmi, а також перевірку зовнішніх контрактів-залежностей (Chainlink AggregatorV3).

1.7 A07:2021 - Identification and Authentication Failures

Раніше - «Порушення автентифікації». Охоплює слабкі паролі, відсутність MFA, помилки управління сесіями. У Web3-екосистемі традиційної «сесії» не існує; автентифікація замінюється криптографічними підписами. Натомість виникають специфічні ризики: підключення гаманця до шкідливого dApp, «сліпий підпис» (blind signing) повідомлень без розуміння їх змісту, ризики EIP-4337 account abstraction.

1.8 A08:2021 - Software and Data Integrity Failures

Нова категорія 2021 року. Охоплює незахищені CI/CD пайплайни, автоматичні оновлення без перевірки підпису, десеріалізацію ненадійних даних. Атака SolarWinds (2020) і численні компрометації прм-пакетів демонструють цей ризик. Для dApps критично, що фронтенд зазвичай завантажує JS-бандл із CDN або IPFS, і цілісність цього бандлу визначає, чи взаємодіє користувач із справжнім протоколом.

1.9 A09:2021 - Security Logging and Monitoring Failures

Недостатнє логування і моніторинг ускладнюють виявлення інцидентів. OWASP рекомендує журналювати всі події автентифікації, збої контролю доступу та аномалії бізнес-логіки. Блокчейн за своєю природою є незмінним публічним журналом, що є перевагою. Однак off-chain компоненти (governance-сервіси, RPC-шлюзи, API) потребують окремої інфраструктури логування.

1.10 A10:2021 - Server-Side Request Forgery (SSRF)

SSRF виникає, коли сервер виконує HTTP-запити до довільних адрес без перевірки URL. Для dApps ризик SSRF сконцентрований у backend-сервісах, що взаємодіють із блокчейн-вузлами, IPFS-шлюзами, серверами метаданих токенів і governance API. Вразливість SSRF у routing-API може дозволити зловмиснику перенаправити RPC-запити на підроблений вузол.

2 Архітектура протоколу Aave v3

Aave v3 - це набір смарт-контрактів, розгорнутих у різних EVM-сумісних мережах, що реалізують логіку децентралізованого ринку кредитування. Архітектура складається з кількох логічних рівнів [2, 5].

Рівень	Компоненти	Функція
Рівень 5: Фронтенд	app.aave.com (React/Next.js, Cloudflare)	Інтерфейс користувача; підключення гаманця; відображення ринкових даних
Рівень 4: Off-Chain сервіси	Governance Forum, Snapshot, Tally; BGD Labs Risk Engine; Chainlink Price Feeds; The Graph Subgraph	Управління протоколом; підрахунок ризику; індексація on-chain подій
Рівень 3: Периферійні контракти	AaveV3Pool (entry point); FlashLoanLogic; BorrowLogic; LiquidationLogic; Permit; wETH Gateway	Логіка кредитування/запозичення; роутинг; flash loans; wrapping ETH
Рівень 2: Ядро протоколу	PoolAddressesProvider; PriceOracle (Chainlink AggregatorV3); AaveOracle; ReserveConfiguration; aTokens (ERC-20); debtTokens	Реєстр адрес; цінові оракули; облік депозитів і боргів; конфігурація резервів
Рівень 1: Блокчейн	Ethereum L1, Polygon, Arbitrum, Optimism, Base, Avalanche, тощо	EVM-виконання; консенсус; mempool; блокпродукція

2.1 Ядро протоколу (Рівень 2–3)

Центральним контрактом Aave v3 є Pool (раніше LendingPool), який виступає єдиною точкою входу для всіх операцій користувача: supply, borrow, repay, withdraw, liquidationCall, flashLoan. Pool делегує виконання спеціалізованим бібліотечним контрактам (SupplyLogic, BorrowLogic тощо) через DELEGATECALL, що дозволяє обходити обмеження розміру контракту Ethereum (24 КБ) [5].

PoolAddressesProvider є єдиним реєстром, що зберігає актуальні адреси всіх контрактів системи. Це ключова точка безпеки: компрометація PoolAddressesProvider дозволить підмінити будь-який компонент протоколу.

aToken (наприклад, aUSDC, aWETH) - це ERC-20 токен, що представляє частку постачальника в резерві. Його баланс збільшується з часом, відображаючи нараховані відсотки. debtToken (variableDebtToken / stableDebtToken) представляє зобов'язання позичальника. Механізм Health Factor (HF) визначає платоспроможність позиції: якщо $HF < 1$, позиція може бути ліквідована.

2.2 Оракули та управління ризиком (Рівень 4)

Aave покладається на Chainlink Price Feeds як основне джерело цінових даних. AaveOracle агрегує відповіді від Chainlink AggregatorV3Interface і використовується для розрахунку вартості застави та боргу. Якість даних оракула є критичним параметром безпеки: маніпуляція ціною може призвести до необґрунтованих ліквідацій або надмірного запозичення.

BGD Labs (Blockchain & DeFi) та Aave Risk Team підтримують Risk Engine - off-chain службу, що відстежує ризик-параметри резервів (LTV, Liquidation Threshold, Reserve Factor, Supply/Borrow Caps) і пропонує їх коригування через governance. Параметри застосовуються on-chain лише після проходження пропозиції через Aave Governance v3.

2.3 Управління (Governance) та Safety Module

Aave Governance v3 базується на токени AAVE/stkAAVE. Власники tokenів можуть подавати пропозиції та голосувати. Пропозиції проходять обов'язкову затримку виконання (timelock: 24 год для Guardian, 48–72 год для Short Executor, 7 днів для Long Executor) [6]. Safety Module - це смарт-контракт, куди AAVE-холдери можуть стейкати токени, отримуючи stkAAVE і право на частину reserve factor. У разі дефіциту (shortfall event) до 30% застейканих коштів може бути «зрізано» (slashing) для покриття боргу протоколу.

2.4 Flash Loans

Flash Loans - це незабезпечені позики, де запозичення і повернення відбуваються в межах однієї транзакції. Aave v3 надає два варіанти: flashLoan (стандартний, з перевіркою return) та flashLoanSimple (оптимізований для одного активу). Flash loans широко використовуються для арбітражу, самоліквідації та рекомпозиції позицій. Водночас вони є потужним інструментом для атаки: зловмисник може тимчасово позичити мільйони доларів для маніпуляції станом інших протоколів [7].

3 OWASP Smart Contract Top 10 (2025)

У 2025 році OWASP оновив перелік найкритичніших вразливостей смарт-контрактів [8]. Наведу коротку характеристику кожної категорії з акцентом на її прояви в DeFi-кредитних протоколах на кшталт Aave.

Ранг	Категорія	Серйозність	Прояв в Aave-подібних протоколах
SC01	Reentrancy Attacks	Критична	Повторний вхід до supply/withdraw через callback ERC-777 або нестандартних токенів
SC02	Integer Overflow/Underflow	Висока	Некоректний розрахунок індексів ліквідності (RAY = $1e27$) при операціях з масштабуванням
SC03	Timestamp Dependence	Середня	Залежність від block.timestamp при розрахунку відсотків; маніпуляція валідатором
SC04	Access Control Vulnerabilities	Критична	Неавторизований виклик setReserveInterestRateStrategy або оновлення PoolAddressesProvider
SC05	Front-Running та MEV	Висока	Sandwich-атаки на ліквідації; sandwich при великих swaps через інтегровані DEX
SC06	Denial of Service (DoS)	Висока	Газові атаки через нескінченні резерви або блокування ліквідаційних транзакцій
SC07	Logic Errors	Висока	Помилки в розрахунку Health Factor або неправильний accounting aToken balances
SC08	Insecure Randomness	Середня	Залежність від pseudo-random при виборі ліквідатора або розподілі rewards
SC09	Gas Limit Issues	Середня	Ліквідація великих позицій з багатьма резервами може перевищити gas block limit
SC10	Unchecked External Calls	Висока	Неперевірені виклики до Chainlink oracle або до flash loan callback-контракту

3.1 SC01: Reentrancy в контексті Aave

Класична reentrancy (виявлена під час злому DAO у 2016 р., ~3.6 млн ETH) реалізується через callback до зовнішнього контракту до оновлення внутрішнього стану. Aave v3 використовує ReentrancyGuard OpenZeppelin у Pool-контракті та дотримується патерну Checks-Effects-Interactions (CEI). Проте cross-protocol reentrancy через ERC-777 або нестандартні токени залишається ризиком для майбутніх резервів [9].

У 2025 році протокол Euler Finance (схожий за архітектурою) зазнав атаки reentrancy-типу через некоректний облік donateToReserves. Це підтверджує актуальність вимог до перевірки стану до будь-якого зовнішнього виклику.

3.2 SC04: Контроль доступу в Aave

Aave v3 реалізує систему ролей через ACLManager (замінив LendingPoolConfigurator). Ключові ролі: POOL_ADMIN, EMERGENCY_ADMIN, RISK_ADMIN, FLASH_BORROWER, BRIDGE_PROTOCOL_FEE_VAULT. Рада Guardian може призупиняти резерви в emergency-режимі. Критично, що всі адміністративні зміни

проходять через PoolAddressesProvider, а той, у свою чергу, контролюється governance multisig із таймлоком [6].

3.3 SC05: MEV та ліквідації

Ліквідаційний механізм Aave відкритий: будь-хто може викликати liquidationCall для позиції з $NF < 1$, отримавши ліквідаційний бонус (5–15% залежно від активу). Це створює конкуренцію серед ліквідаторів і MEV-бота, які відстежують mempool, намагаючись перехопити вигідні ліквідаційні транзакції шляхом front-running або sandwich-атак. У 2026 році MEV Bundle від Flashbots залишається стандартом для «захищених» ліквідацій [10].

4 Зіставлення OWASP з безпекою Aave v3

У цьому розділі я систематично зіставляю кожен категорію OWASP Top 10:2021 з конкретними проявами у архітектурі Aave v3, описую реальні або гіпотетичні сценарії атак і вказую, як протокол їх пом'якшує.

4.1 A01 → Aave: Контроль доступу

Рівень смарт-контрактів: Aave v3 реалізує детальну RBAC-модель через ACLManager. Функції `setReserveInterestRateStrategy`, `dropReserve`, `initReserve` доступні лише для `POOL_ADMIN`, що контролюється `governance multisig`. Функція `setEmergencyAdmin` дозволяє спільноті швидко реагувати на інциденти без повного `governance`-голосування.

Рівень фронтенду: `app.aave.com` перевіряє підключений гаманець, але, як і в будь-якому dApp, всі перевірки фронтенду є лише UX-бар'єрами - реальний захист забезпечується смарт-контрактами. Governance-рівень: токен `AAVE/stkAAVE` надає право голосувати та пропонувати зміни, але виконання можливе лише після таймлоку.

4.2 A02 → Aave: Криптографічні залежності

Aave використовує стандартну Ethereum-криптографію (`secp256k1`, `keccak256`). Додатково `Permit2` та `EIP-712` дозволяють підписувати off-chain авторизації на постачання або запозичення. Критичний сценарій: якщо приватний ключ `governance multisig` скомпрометований, зловмисник може підписати транзакцію, яка оновить `PoolAddressesProvider` на шкідливий контракт. Захист: `Gnosis Safe multisig` із мінімум 5 з 9 підписів для `Long Executor` [6].

4.3 A03 → Aave: Ін'єкції

На рівні фронтенду: React-додаток обробляє введені користувачем адреси токенів, суми, `slippage`-налаштування. XSS може призвести до підміни параметрів транзакції. На рівні смарт-контрактів: `bytes calldata params` у `flashLoan` використовуються для передачі даних до `callback`-контракту. Aave перевіряє, що після повернення коштів `balance` збільшився на `fee`, але не валідує вміст `params`, тому відповідальність за безпеку `callback` лежить на розробнику `receiver`-контракту.

4.4 A04 → Aave: Небезпечний дизайн

Дизайн Aave v3 включає кілька `security-by-design` рішень. `Supply/Borrow Caps` обмежують максимальний обсяг кожного резерву, знижуючи ризик надмірної концентрації. `eMode` (`efficiency mode`) дозволяє вищий `LTV` лише для корельованих активів (наприклад, `stETH/ETH`), що обмежує арбітражні вектори. `Price Oracle Sentinel` забезпечує `grace period` після відновлення зупиненого оракула, щоб уникнути `mass liquidation` [5].

Водночас незмінність основних контрактів є подвійним мечем: виявлений дефект дизайну потребує міграції, що є складним управлінським процесом з ризиком втрати стану та довіри спільноти.

4.5 A05 → Aave: Конфігураційні ризики

Фронтенд-інфраструктура: `app.aave.com` залежить від DNS, CDN (Cloudflare), TLS-сертифікатів. У 2023 році атака на DNS Curve Finance показала цей ризик для DeFi-фронтендів загалом. IPFS-деплой Aave доступний як альтернатива, але більшість користувачів звертаються через DNS. Конфігурація оракула: неправильна адреса Chainlink feed при ініціалізації резерву може призвести до розрахунку вартості застави на основі некоректних даних.

4.6 A06 → Aave: Залежності

Смарт-контракти Aave залежать від OpenZeppelin (SafeERC20, AccessControl, ReentrancyGuard, Pausable). Фронтенд використовує `ethers.js`, `wagmi`, `viem`, `react-query`, `@aave/contract-helpers`. Кожна залежність - потенційний вектор атаки на ланцюжок постачання. Наприклад, компрометація `aave/contract-helpers` могла б дозволити підміну параметрів транзакції ще на рівні SDK.

4.7 A07 → Aave: Автентифікаційна модель

Aave повністю базується на wallet-based автентифікації: MetaMask, WalletConnect, Coinbase Wallet, Safe (multisig). Традиційних вразливостей автентифікації (credential stuffing, session fixation) не існує, проте виникають специфічні ризики: blind signing (підпис `setUserUseReserveAsCollateral` або `approve ERC-20` без розуміння наслідків), фішингові dApps, що імітують Aave UI та запитують unlimited approval до pool-контракту.

4.8 A08 → Aave: Цілісність коду

Aave розгортає фронтенд на IPFS (content-addressed), зберігаючи хеш в ENS (`aave.eth`). Традиційний DNS (`app.aave.com`) залишається основним шляхом доступу, що повертає централізовані ризики. Всі виходи GitHub підписані, проте більшість кінцевих користувачів не перевіряє SRI-хеші. CI/CD pipeline Aave включає аудити перед кожним major release.

4.9 A09 → Aave: Моніторинг та реагування

On-chain активність Aave повністю логована: кожна операція emit відповідну подію (Deposit, Borrow, Repay, LiquidationCall тощо). The Graph індексує ці події. BGD Labs підтримує Aave Sentinel - систему моніторингу, яка відстежує здоров'я протоколу в реальному часі. Додатково, OpenZeppelin Defender Sentinel налаштований на критичні адміністративні дії [11].

4.10 A10 → Aave: SSRF-подібні ризики в off-chain сервісах

Aave Risk Engine та governance-агрегатори звертаються до зовнішніх API (Chainlink node operators, DeFiLlama, Coingecko) для збору ринкових даних. Якщо ці сервіси не перевіряють вхідні URI або не валідують відповіді, SSRF може дозволити розкрити внутрішні endpoints. Критичнішим є ризик маніпуляції даними оракула: якщо SSRF дозволить підмінити ціновий потік, розрахунок Health Factor стане некоректним.

5 Перелік вимог безпеки для dApp Aave v3

На основі попереднього аналізу я сформулював структурований перелік вимог безпеки, організованих за архітектурними рівнями Aave. Кожній вимозі присвоєно унікальний ідентифікатор, рівень критичності та посилання на джерело (OWASP або SC Top 10).

5.1 Вимоги до рівня смарт-контрактів

ID	Вимога	Рівень	Джерело
SC-01	Всі зовнішні виклики у функціях supply/withdraw/borrow/repay повинні виконуватися ПІСЛЯ оновлення внутрішнього стану (патерн CEI). Використовувати nonReentrant modifier у всіх state-changing функціях Pool.	Критичний	SC01, A01
SC-02	Всі арифметичні операції з індексами ліквідності ($RAY = 1e27$) та WEI-масштабуванням повинні використовувати SafeMath або Solidity $\geq 0.8.x$. Будь-яке unchecked-блоки мають бути формально обґрунтовані.	Критичний	SC02, A04
SC-03	ACLManager повинен бути єдиним реєстром дозволів. Жодна функція Pool не повинна виконувати привілейовані дії без перевірки через ACLManager.hasRole(). Заборонено використовувати tx.origin.	Критичний	SC04, A01
SC-04	PoolAddressesProvider повинен контролюватися multisig із timelock ≥ 48 год. Будь-яке оновлення адреси (setPoolImpl, setPriceOracle) повинно проходити governance голосування.	Критичний	SC04, A04
SC-05	Flash loan callback (executeOperation) повинен верифікувати initiator та що виклик походить від авторизованого Pool-контракту. Повернена сума + fee повинна перевірятися після callback.	Висока	SC01, A03
SC-06	Функції ліквідації (liquidationCall) повинні реалізовувати slippage-захист для ліквідатора та обмеження максимальної суми ліквідації за одну транзакцію, щоб запобігти DoS через газ.	Висока	SC05, SC06
SC-07	Розрахунок Health Factor повинен використовувати TWAP або агреговані оракульні дані з перевіркою актуальності (staleness check: не старіші за 3600 сек). Відхилення ціни $>10\%$ від TWAP повинно призупиняти ліквідацію.	Висока	SC03, SC10
SC-08	Supply Cap та Borrow Cap для кожного резерву повинні бути встановлені ненульовими значеннями та регулярно переглядатися Risk Team. Це обмежує максимальний збиток при атаці.	Висока	SC07, A04
SC-09	Всі state-changing події повинні emit відповідні Solidity events з індексованими параметрами (asset, user, amount). Мінімальний набір: Deposit, Borrow, Repay, Withdraw, LiquidationCall, ReserveDataUpdated.	Середній	A09, SC07
SC-10	Всі зовнішні залежності (OpenZeppelin, Chainlink AggregatorV3) повинні бути зафіксовані на конкретній перевірненій версії. Будь-яке оновлення потребує окремого governance-голосування та аудиту.	Середній	A06

SC-11	Нові резерви повинні проходити процедуру ризик-оцінки: перевірку liquidity, volatility, smart contract risk до включення. Price oracle для нового резерву повинен мати резервний feed.	Висока	A04, SC10
SC-12	eMode-конфігурації повинні дозволятися лише для активів із доведеною кореляцією (наприклад, stETH/wstETH/ETH). Кореляційне допущення повинно регулярно ревалідуватися Risk Team.	Висока	SC07, A04

5.2 Вимоги до фронтенду

ID	Вимога	Рівень	Джерело
FE-01	Content Security Policy (CSP) повинна забороняти inline-скрипти, eval() та завантаження ресурсів із ненадійних джерел. HSTS, X-Content-Type-Options, X-Frame-Options є обов'язковими заголовками.	Критичний	A03, A05
FE-02	Всі фронтенд-збірки повинні бути прив'язані до IPFS із хешами вмісту, записаними в ENS (aave.eth). Традиційний DNS повинен використовувати DNSSEC + CAA записи.	Критичний	A08
FE-03	Відображення транзакцій перед підписом повинно включати: назву операції, актив, суму, адресу отримувача, estimated gas cost, Health Factor після операції. Blind signing неприпустимий.	Висока	A07, SC05
FE-04	При введенні адрес токенів вручну або імпорті нового токена - верифікація за EIP-55 checksum та перевірка за curated token list (Aave Token List). Попередження для невідомих токенів.	Висока	A03, A05
FE-05	Відображати користувачу Health Factor в реальному часі та попереджати про ризик ліквідації (HF < 1.2). Кнопка "Supply More" або "Repay" повинна бути доступна з попереджувального банера.	Висока	A07, SC07
FE-06	Subresource Integrity (SRI) для всіх сторонніх JS та CSS ресурсів (ethers.js CDN, wagmi тощо). Використання package-lock.json або yarn.lock для детермінованих збірок.	Висока	A06, A08
FE-07	При підключенні гаманця чітко відображати запитувані дозволи. ERC-20 approval повинен бути обмеженим (не unlimited), якщо тільки користувач свідомо не обирає unlimited.	Висока	A01, A07
FE-08	Rate limiting RPC-запитів на клієнтській стороні. Fallback на резервний RPC-провайдер (наприклад, Alchemy → Infura → публічний node) при недоступності основного.	Середній	A10

5.3 Вимоги до off-chain інфраструктури

ID	Вимога	Рівень	Джерело
----	--------	--------	---------

IF-01	Risk Engine та governance-агрегатори повинні валідувати всі зовнішні URI (API токен-метаданих, price feeds) за allowlist. Запобігання SSRF шляхом розмежування мережевого доступу.	Висока	A10
IF-02	RPC-з'єднання повинні використовувати автентифіковані endpoints із TLS 1.3. Мінімум два незалежних RPC-провайдери для redundancy. Перевірка відповідей на маніпуляцію (chainId, blockNumber monotonicity).	Критичний	A02, A05
IF-03	Дані The Graph subgraph повинні крос-перевірятися з прямими on-chain зчитуваннями для критичних операцій (поточний HF, reserve availability). Не покладатися виключно на indexed data.	Висока	A04, A08
IF-04	CI/CD пайплайн для фронтенду та SDK (@aave/contract-helpers) повинен вимагати multi-party review, signed commits, reproducible builds та автоматичного SAST-аналізу.	Висока	A08
IF-05	Моніторинг аномалій в реальному часі: незвичний обсяг flash loans, різкі зміни liquidity, великі ліквідаційні транзакції в одному блоці, нові незвичні адреси в governance.	Середній	A09, SC05
IF-06	Оновлення залежностей npm повинні проходити автоматичне сканування (Snyk/npm audit) перед merging. Dependency Review GitHub Action для контролю нових залежностей у PR.	Середній	A06
IF-07	Chainlink Price Feeds повинні мати staleness check (не старіші за configurable threshold). При відсутності даних від оракула (downtime) - активація Oracle Sentinel: grace period перед ліквідаціями.	Критичний	SC10, A10

5.4 Вимоги до управління та операцій

ID	Вимога	Рівень	Джерело
GV-01	Всі governance пропозиції повинні проходити обов'язковий timelock delay (Short Executor ≥ 24 год, Long Executor ≥ 7 днів) перед виконанням. Guardian може скасовувати пропозиції без timelock.	Висока	A01, A04
GV-02	Перед деплоєм нових версій контрактів або нових резервів - мінімум два незалежних аудити від авторитетних компаній (Trail of Bits, OpenZeppelin, Certora) з публікацією звітів.	Критичний	A04, A06
GV-03	Підтримувати активну програму Bug Bounty (Immunefi) з виплатами, пропорційними TVL (станом на 2026 - \$16M за критичні вразливості в смарт-контрактах).	Висока	A09
GV-04	Підтримувати детальний план реагування на інциденти: компрометація фронтенду, exploit смарт-контракту, governance attack, маніпуляція оракулом, shortfall event. Включати контакти Emergency Admin.	Середній	A09
GV-05	Проводити penetration testing фронтенд-інфраструктури та off-chain сервісів щонайменше раз на квартал.	Середній	A05, A10

	Включати тестування соціальної інженерії проти членів команди.		
GV-06	Адміністративні ключі governance multisig повинні зберігатися на апаратних гаманцях (Ledger/Trezor). Обов'язкова ротація підписантів multisig за графіком або при зміні складу команди.	Критичний	A02, A07
GV-07	Safety Module повинен мати достатній буфер ліквідності для покриття shortfall event найбільшого резерву. Регулярно перевіряти sufficiency через стрес-тести.	Висока	SC07, A04

6 Зведена таблиця відповідності вимог OWASP ↔ Aave v3

Категорія OWASP	Назва	Вимоги Aave v3
A01	Broken Access Control	SC-03, SC-04, FE-07, GV-01, GV-06
A02	Cryptographic Failures	IF-02, GV-06
A03	Injection	SC-05, FE-01, FE-04
A04	Insecure Design	SC-02, SC-04, SC-08, SC-11, SC-12, IF-03, GV-01, GV-02, GV-07
A05	Security Misconfiguration	FE-01, FE-04, FE-06, IF-02, GV-05
A06	Vulnerable Components	SC-10, FE-06, IF-06, GV-02
A07	Auth Failures	FE-03, FE-05, FE-07, GV-06
A08	Integrity Failures	SC-10, FE-02, FE-06, IF-03, IF-04
A09	Logging & Monitoring	SC-09, IF-05, GV-03, GV-04
A10	SSRF	IF-01, IF-07, FE-08, GV-05

Загалом сформульовано 33 вимоги: 8 критичних, 17 високих та 8 середніх. Найбільша кількість припадає на рівень смарт-контрактів (12 вимог), що відображає незворотній характер on-chain вразливостей. Рівень управління має найбільшу частку критичних вимог - адже компрометація governance-процесів може призвести до повного захоплення протоколу.

Висновки

У цій лабораторній роботі я дослідив вимоги безпеки веб-додатків OWASP Top 10:2021 та зіставив їх із архітектурою та безпековими характеристиками децентралізованого протоколу кредитування Aave v3.

Стандарт OWASP Top 10:2021 залишається актуальним і для децентралізованих додатків, але вимагає суттєвого переосмислення в контексті блокчейну. Традиційні категорії - Broken Access Control, Injection, Security Misconfiguration - проявляються у dApps у принципово інших формах. Контроль доступу кодується в незмінній логіці смарт-контракту через ACLManager замість серверного middleware; ін'єкції охоплюють зловмисні calldata поряд із класичним XSS; ризики конфігурації концентруються на DNS/CDN-інфраструктурі та параметрах ініціалізації контрактів.

Специфіка DeFi-кредитних протоколів додає унікальні вектори атак, що не мають аналогів у традиційній веб-безпеці. Flash loans як інструмент маніпуляції цінними оракулами, MEV та front-running на ліквідаційних транзакціях, reentrancy через нестандартні token callbacks, залежність від зовнішніх оракулів Chainlink - все це вимагає спеціалізованих вимог, що виходять за рамки OWASP Top 10:2021. OWASP Smart Contract Top 10 (2025) надає необхідне додаткове покриття.

Aave v3 демонструє зрілий підхід до безпеки: незалежні аудити від Trail of Bits, OpenZeppelin та Certora; програма Bug Bounty на \$16M; Oracle Sentinel для захисту від oracle-downtime; Supply/Borrow Caps для обмеження ризику; Safety Module як буфер проти shortfall events. Водночас залишаються виклики: більшість користувачів використовують DNS-версію фронтенду (не IPFS/ENS), що зберігає централізовані ризики; MEV-ботики продовжують отримувати надлишковий прибуток на ліквідаціях.

Сформульований перелік із 33 вимог безпеки охоплює чотири рівні архітектури: смарт-контракти, фронтенд, off-chain інфраструктуру та управління. Жоден рівень не може існувати ізольовано - як показав DNS-атака на Curve Finance у 2023 році та злом Drift Protocol у квітні 2026 року, ідеально захищені смарт-контракти не рятують від компрометації механізмів доставки або governance-процесів.

Список використаних джерел

- [1] DeFiLlama. Total Value Locked in DeFi, 2026. URL: <https://defillama.com>
- [2] Aave Labs. Aave v3 Technical Paper. 2022. URL: https://github.com/aave/aave-v3-core/blob/master/techpaper/Aave_V3_Technical_Paper.pdf
- [3] Immunefi. Crypto Losses Q1 2026 Report. 2026. URL: <https://immunefi.com/research>
- [4] OWASP Foundation. OWASP Top 10:2021. URL: <https://owasp.org/Top10>
- [5] Aave Labs. Aave v3 Core Smart Contracts Documentation, 2023. URL: <https://github.com/aave/aave-v3-core>
- [6] Aave Foundation. Aave Governance v3 Documentation. 2024. URL: <https://governance.aave.com>
- [7] Qin K., Zhou L., Gervais A. Quantifying Blockchain Extractable Value: How dark is the forest? IEEE SP 2022.
- [8] OWASP Foundation. OWASP Smart Contract Top 10 (2025). URL: <https://owasp.org/www-project-smart-contract-security>
- [9] OpenZeppelin. ReentrancyGuard Documentation. URL: <https://docs.openzeppelin.com/contracts/5.x/api/utils>
- [10] Flashbots. MEV-Boost: Ethereum Block Building. URL: <https://boost.flashbots.net>
- [11] OpenZeppelin Defender. Sentinel: Real-Time Monitoring for Smart Contracts. URL: <https://www.openzeppelin.com/defender>
- [12] Chainlink Labs. Chainlink Price Feeds Documentation. 2024. URL: <https://docs.chain.link/data-feeds>
- [13] Trail of Bits. Aave v3 Security Assessment. 2022. URL: <https://github.com/aave/aave-v3-core/blob/master/audits>